Quantum Bill of Materials

Acme Corp

Generated 2026-09-27T05:53:25.034606+00:00 · catalog v1 (5a06fc0a9f41...)

Readiness summary

Total crypto findings	53 across 23 distinct algorithms/protocols
Quantum-safe today (PQ_SAFE + HYBRID)	13.2%
Shor-vulnerable (existential break under a CRQC)	45.3%
Grover-weakened (margin reduction only)	5.7%
Already classically broken/deprecated	35.8%

Prioritised migration plan

#	Algorithm	Threat	Count	Exposure	Lifetime	Score	Replacement
1	ECC P-256 (ECDSA/ECDH) `EC-P256`	SHOR	4	internet_facing	15y	1216.8	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
2	RSA (<2048-bit) `RSA-SUB2048`	SHOR	4	internet_facing	15y	1216.8	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware; and stop using <2048 now
3	MD5 `MD5`	CLASSICAL_BROKEN	4	internet_facing	15y	327.6	SHA-256 / SHA3-256 (or SHA-384 for CNSA 2.0)
4	ECB mode (misuse) `MODE-ECB`	CLASSICAL_BROKEN	2	internet_facing	15y	321.3	AES-256-GCM (AEAD)
5	Ed25519 `ED25519`	SHOR	2	internal	7y	250.9	ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
6	X25519 `X25519`	SHOR	2	internal	7y	250.9	Hybrid X25519MLKEM768 now, ML-KEM-768 later
7	AES (key size unknown) `AES-UNK`	GROVER	2	internet_facing	15y	137.7	Verify key size; use AES-256
8	RSA (size unknown) `RSA-UNK`	SHOR	7	internal	1y	88.6	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
9	TLS 1.2 `TLS1.2`	SHOR	2	internal	1y	84.5	TLS 1.3 with hybrid PQ key exchange

#	Algorithm	Threat	Count	Exposure	Lifetime	Score	Replacement
10	DH/FFDH (<2048-bit) DH-SUB2048	SHOR	1	internal	1y	83.6	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first; stop using <2048 now
11	RSA-2048 RSA-2048	SHOR	1	internal	1y	83.6	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
12	TLS 1.3 (classical KEX) TLS1.3	SHOR	1	internal	1y	83.6	Enable X25519MLKEM768 key share
13	SHA-1 SHA1	CLASSICAL_BROKEN	6	internal	2y	66.8	SHA-256 / SHA3-256 (or SHA-384 for CNSA 2.0)
14	3DES 3DES	CLASSICAL_BROKEN	2	internal	1y	64.3	AES-256-GCM
15	RC4 RC4	CLASSICAL_BROKEN	2	internal	1y	64.3	AES-256-GCM or ChaCha20-Poly1305
16	DES DES	CLASSICAL_BROKEN	1	internal	1y	63.6	AES-256-GCM
17	TLS 1.0 TLS1.0	CLASSICAL_BROKEN	1	internal	1y	63.6	TLS 1.3 with hybrid PQ key exchange
18	TLS 1.1 TLS1.1	CLASSICAL_BROKEN	1	internal	1y	63.6	TLS 1.3 with hybrid PQ key exchange
19	AES-128 AES-128	GROVER	1	internal	1y	27.3	AES-256 (CNSA 2.0 requires 256-bit keys)
20	Hybrid KEM (classical+ML-KEM) HYBRID-KEM	HYBRID	1	internal	1y	9.1	Later: pure ML-KEM where policy allows
21	SHA-256 SHA-256	PQ_SAFE	3	internal	7y	6.2	none needed
22	AES-256 AES-256	PQ_SAFE	2	internal	1y	3.7	none needed
23	ChaCha20(-Poly1305) CHACHA20	PQ_SAFE	1	internal	1y	3.6	none needed

Detail per item

1. ECC P-256 (ECDSA/ECDH) `(EC-P256)` — *score 1216.8*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 15y, against a ~10y conservative planning horizon.

Occurrences: 4

Affected components: payments-svc

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: samples/vulnerable-app/config/nginx.conf:4, samples/vulnerable-app/certs/modern_service.crt:1, samples/vulnerable-app/certs/modern_service.key:1, samples/vulnerable-app/app/payments/service.py:11

2. RSA (<2048-bit) `(RSA-SUB2048)` — *score 1216.8*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 15y, against a ~10y conservative planning horizon.

Occurrences: 4

Affected components: payments-svc

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware; and stop using <2048 now

Locations: samples/vulnerable-app/config/openssl.cnf:2, samples/vulnerable-app/certs/legacy_partner.crt:1, samples/vulnerable-app/certs/legacy_partner.key:1, samples/vulnerable-app/app/payments/service.py:8

3. MD5 `(MD5)` — *score 327.6*

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 4

Affected components: legacy-batch, payments-svc

Recommended replacement: SHA-256 / SHA3-256 (or SHA-384 for CNSA 2.0)

Locations: samples/vulnerable-app/web-service/crypto-utils.js:4, samples/vulnerable-app/config/nginx.conf:4, samples/vulnerable-app/app/payments/service.py:14, samples/vulnerable-app/app/legacy/hash.py:7

4. ECB mode (misuse) `(MODE-ECB)` — *score 321.3*

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 2

Affected components: payments-svc

Recommended replacement: AES-256-GCM (AEAD)

Locations: samples/vulnerable-app/app/api/AuthService.java:17, samples/vulnerable-app/app/payments/service.py:17

5. Ed25519 `(ED25519)` — *score 250.9*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 7y, against a ~10y conservative planning horizon.

Occurrences: 2

Affected components: vault-svc

Recommended replacement: ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: samples/vulnerable-app/config/sshd_config:5, samples/vulnerable-app/app/crypto/vault.py:9

6. X25519 (X25519) — *score 250.9*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 7y, against a ~10y conservative planning horizon.

Occurrences: 2

Affected components: vault-svc

Recommended replacement: Hybrid X25519MLKEM768 now, ML-KEM-768 later

Locations: samples/vulnerable-app/config/sshd_config:2, samples/vulnerable-app/app/crypto/vault.py:6

7. AES (key size unknown) (AES-UNK) — *score 137.7*

Grover-weakened: effective security roughly halves under a large quantum computer; raise key/output size, no protocol redesign needed.

Occurrences: 2

Affected components: payments-svc, vault-svc

Recommended replacement: Verify key size; use AES-256

Locations: samples/vulnerable-app/app/crypto/vault.py:12, samples/vulnerable-app/app/payments/service.py:17

8. RSA (size unknown) (RSA-UNK) — *score 88.6*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 7

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: samples/vulnerable-app/config/sshd_config:5, samples/vulnerable-app/config/nginx.conf:4, samples/vulnerable-app/config/nginx.conf:4, samples/vulnerable-app/config/nginx.conf:4, samples/vulnerable-app/config/openssl.cnf:4, samples/vulnerable-app/config/openssl.cnf:4, samples/vulnerable-app/app/api/AuthService.java:6

9. TLS 1.2 (TLS1.2) — *score 84.5*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 2

Recommended replacement: TLS 1.3 with hybrid PQ key exchange

Locations: samples/vulnerable-app/config/nginx.conf:3, samples/vulnerable-app/config/openssl.cnf:5

10. DH/FFDH (<2048-bit) (DH-SUB2048) — *score 83.6*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 1

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first; stop using <2048 now

Locations: samples/vulnerable-app/config/sshd_config:2

11. RSA-2048 (RSA-2048) — score 83.6

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 1

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: samples/vulnerable-app/app/api/AuthService.java:7

12. TLS 1.3 (classical KEX) (TLS1.3) — score 83.6

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 1

Recommended replacement: Enable X25519MLKEM768 key share

Locations: samples/vulnerable-app/config/nginx.conf:3

13. SHA-1 (SHA1) — score 66.8

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 6

Affected components: legacy-batch

Recommended replacement: SHA-256 / SHA3-256 (or SHA-384 for CNSA 2.0)

Locations: samples/vulnerable-app/config/sshd_config:4, samples/vulnerable-app/config/nginx.conf:4, samples/vulnerable-app/config/openssl.cnf:4, samples/vulnerable-app/certs/legacy_partner.crt:1, samples/vulnerable-app/app/api/AuthService.java:12, samples/vulnerable-app/app/legacy/hash.py:4

14. 3DES (3DES) — score 64.3

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 2

Recommended replacement: AES-256-GCM

Locations: samples/vulnerable-app/web-service/crypto-utils.js:12, samples/vulnerable-app/config/nginx.conf:4

15. RC4 (RC4) — score 64.3

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 2

Recommended replacement: AES-256-GCM or ChaCha20-Poly1305

Locations: samples/vulnerable-app/config/nginx.conf:4, samples/vulnerable-app/config/openssl.cnf:4

16. DES (DES) — score 63.6

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 1

Recommended replacement: AES-256-GCM

Locations: samples/vulnerable-app/app/api/AuthService.java:17

17. TLS 1.0 (TLS1.0) — score 63.6

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 1

Recommended replacement: TLS 1.3 with hybrid PQ key exchange

Locations: samples/vulnerable-app/config/nginx.conf:3

18. TLS 1.1 (TLS1.1) — score 63.6

Already broken or deprecated against classical attackers today -- fix regardless of quantum timeline.

Occurrences: 1

Recommended replacement: TLS 1.3 with hybrid PQ key exchange

Locations: samples/vulnerable-app/config/nginx.conf:3

19. AES-128 (AES-128) — score 27.3

Grover-weakened: effective security roughly halves under a large quantum computer; raise key/output size, no protocol redesign needed.

Occurrences: 1

Recommended replacement: AES-256 (CNSA 2.0 requires 256-bit keys)

Locations: samples/vulnerable-app/config/nginx.conf:4

20. Hybrid KEM (classical+ML-KEM) (HYBRID-KEM) — score 9.1

Already hybrid classical+PQ; low urgency, monitor for pure-PQ migration once policy allows.

Occurrences: 1

Recommended replacement: Later: pure ML-KEM where policy allows

Locations: samples/vulnerable-app/config/sshd_config:2

21. SHA-256 (SHA-256) — score 6.2

Already quantum-safe with adequate margin.

Occurrences: 3

Affected components: vault-svc

Recommended replacement: none needed

Locations: samples/vulnerable-app/web-service/crypto-utils.js:8, samples/vulnerable-app/certs/modern_service.crt:1, samples/vulnerable-app/app/crypto/vault.py:17

22. AES-256 (AES-256) — score 3.7

Already quantum-safe with adequate margin.

Occurrences: 2

Recommended replacement: none needed

Locations: samples/vulnerable-app/config/sshd_config:3, samples/vulnerable-app/config/openssl.cnf:4

23. ChaCha20(-Poly1305) `(CHACHA20)` *— score 3.6*

Already quantum-safe with adequate margin.

Occurrences: 1

Recommended replacement: none needed

Locations: `samples/vulnerable-app/config/sshd_config:3`